



MASTG

- Runtime Use of Logging APIs
- MASTG-TEST-0207: Runtime Storage of Unencrypted Data in the App Sandbox
- MASTG-TEST-0216: Sensitive Data Not Excluded From Backup
- MASTG-TEST-0231: References to Logging APIs
- MASTG-TEST-0262: References to Backup Configurations Not Excluding Sensitive Data
- MASTG-TEST-0287: Sensitive Data Stored Unencrypted via the SharedPreference API to the App Sandbox
- MASTG-TEST-0304: Sensitive Data Not Excluded From Backup

L1L2PANDROIDMASWE-0004TEST



MASTG-TEST-0262: References to Backup Configurations Not Excluding Sensitive Data

Overview

This test verifies whether apps correctly instruct the system to exclude sensitive files from backups by analyzing the app's AndroidManifest.xml and backup rule configuration files.

"Android Backups" ([🔗 Backups](#)) can be implemented via [Auto Backup ↗](#) (Android 6.0 (API level 23) and higher) and [Key-value backup ↗](#) (Android 2.2 (API level 8) and higher). Auto Backup is the recommended approach by Android as it is enabled by default and requires no work to implement.

To exclude specific files when using Auto Backup, developers must explicitly define exclusion rules in the `exclude` tag in:

- `data_extraction_rules.xml` (for Android 12 and higher using `android:dataExtractionRules`)
- `backup_rules.xml` (for Android 11 or lower using `android:fullBackupContent`)

The `cloud-backup` and `device-transfer` parameters can be used to exclude files from cloud backups and device-to-device transfers, respectively.

The key-value backup approach requires developers to set up a [BackupAgent ↗](#) or [BackupAgentHelper ↗](#) and specify what data should be backed up.

Regardless of which approach the app used, Android provides a way to start the backup daemon to back up and restore app files. You can use this daemon for testing purposes and initiate the backup process and restore the app's data, allowing you to verify which files were restored from the backup.

Steps

- Obtain the `AndroidManifest.xml` file using [🔗 Obtaining Information from the AndroidManifest](#).
- Search for the `allowBackup` flag in the `AndroidManifest.xml`.
- Search for the `fullBackupContent` attribute (for Android 11 or lower) or the `dataExtractionRules` attribute (for Android 12 and higher) in the `AndroidManifest.xml`.
- Retrieve the `backup_rules.xml` or `data_extraction_rules.xml` file.

Observation

The output should explicitly show:

- whether the `allowBackup` flag is set to `true` or `false`. If the flag is not specified, it is treated as `true` by default.
- whether the `fullBackupContent` and/or `dataExtractionRules` attributes are present in the `AndroidManifest.xml`.
- the contents of the `backup_rules.xml` or `data_extraction_rules.xml` file, if present.

Evaluation

The test fails if the app allows sensitive data to be backed up. Specifically, if the following conditions are met:

- `android:allowBackup="true"` in the `AndroidManifest.xml`
- `android:fullBackupContent="@xml/backup_rules"` isn't declared in the `AndroidManifest.xml` (for Android 11 or lower)
- `android:dataExtractionRules="@xml/data_extraction_rules"` isn't declared in the `AndroidManifest.xml` (for Android 12 and higher)
- `backup_rules.xml` or `data_extraction_rules.xml` aren't present or don't exclude all sensitive files.

Best Practices

📱 MASTG-BEST-0004: Exclude Sensitive Data from Backups

Demos

📱 MASTG-DEMO-0034: Backup and Restore App Data with semgrep

